

VulnTriage

AI-Assisted Vulnerability Triage & Confirmation Using ML and Multi-Scanner Analysis

Raabindra

BSc (Hons) in Cyber Security

TP0707

VulnTriage is an AI-assisted system that automatically triages and confirms the findings produced by web-vulnerability scanners. It ingests reports from multiple scanners — OWASP ZAP, Nuclei and Nessus — then normalises, de-duplicates, enriches, prioritises and confirms every finding through a single automated pipeline.

Its goal is to cut the manual effort and false-positive noise of vulnerability triage by producing an **explainable, evidence-backed confidence verdict** for each finding — telling the analyst which vulnerabilities are real, how severe they are, and how to fix them.

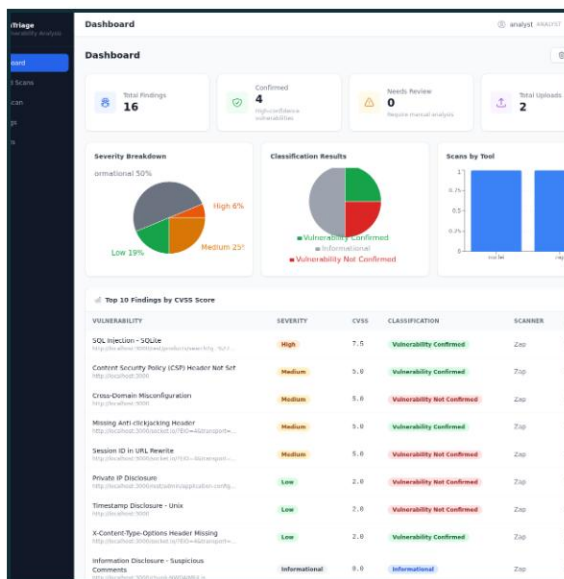
Problem Statement

Automated scanners flood analysts with findings, many of which are false positives or informational noise. Verifying each one by hand is slow, repetitive and error-prone — a problem known as **alert fatigue**.

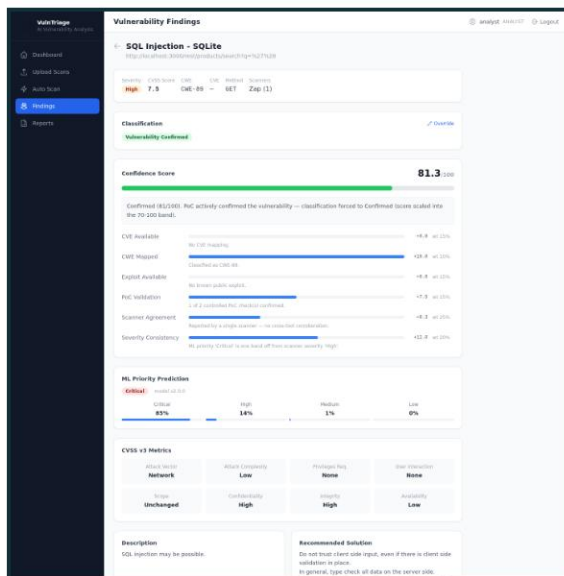
Different scanners also report the same issue in different formats, creating duplicates and inconsistency, and it is hard to tell which findings are genuinely exploitable and worth acting on.

Benefits

- 1 Confirms real vulnerabilities by active Proof-of-Concept testing, not guesswork.
- 2 Cuts false-positive noise, shrinking the review set to what truly matters.
- 3 Prioritises findings with a machine-learning model (99.68% accuracy).
- 4 Explains every verdict with a transparent six-factor confidence score.
- 5 Merges duplicate findings from multiple scanners automatically.
- 6 Produces a professional, shareable PDF report with AI-written analysis.



Dashboard — triage overview & KPIs



Finding detail — confidence & rationale



Features

- Multi-scanner ingestion (ZAP, Nuclei, Nessus)
- Machine-learning prioritisation
- Six-factor confidence scoring
- Active Proof-of-Concept validation
- AI-assisted analysis (Gemini / Claude)
- Professional PDF reporting
- Authorised Auto Scan

Specification

- 1 Python (Flask) back end + React front end
- 2 Pure-NumPy Random Forest model
- 3 SQLite / PostgreSQL database
- 4 Runs as desktop app, Docker web app or CLI
- 5 Linux (Kali) / cross-platform

Conclusion

VulnTriage shows that machine learning, multi-scanner corroboration and active PoC validation can be combined into one explainable triage system.

On a real OWASP Juice Shop scan it confirmed every genuine vulnerability — including an exploited SQL injection — and demoted all noise, meaningfully reducing triage effort while keeping every decision transparent and evidence-backed.